

Vulnerability Assessment Report

Risk-based prioritization, remediation ownership, SLA guidance, and validation

Environment. Representative assessment of internet-facing services, internal servers, workstations, and cloud workloads. Findings demonstrate prioritization methodology using CVSS-style severity plus business context; CVE identifiers are intentionally not invented where no real scan evidence exists.

Executive Summary

- Five priority findings require remediation because of exposure, privilege, or business impact.
- Remediation priority considers exploitability, internet exposure, data sensitivity, compensating controls, and asset criticality in addition to base severity.
- Closure requires rescanning or configuration validation.

ID	Finding	Severity	Affected scope	Business risk	Remediation	SLA	Validation
V-01	Critical security updates missing on internet-facing web servers	Critical	Public web tier	Remote compromise could expose customer data or disrupt service.	Apply vendor updates through emergency change; confirm supported versions; review WAF logs.	7 days	Authenticated rescan shows no critical missing updates.
V-02	Remote administration permits password-based authentication without MFA	Critical	Admin access path	Stolen credentials could enable privileged access.	Require MFA; restrict source networks; disable legacy auth; monitor admin logins.	7 days	Test login requires MFA and blocked legacy method.
V-03	TLS configuration permits legacy protocol / weak cipher options	High	External services	Weak transport security may enable downgrade or interception risk.	Enforce modern TLS; remove deprecated protocols/ciphers; test dependent clients.	30 days	Independent TLS validation shows approved configuration.
V-04	Excessive local administrator membership on employee endpoints	High	Selected workstations	Malware or compromised user may gain elevated execution.	Remove unnecessary admin; use managed elevation; review privileged groups monthly.	30 days	Exported group membership matches approved list.
V-05	Central logging missing from selected critical systems	High	Identity / admin systems	Delayed detection and incomplete incident evidence.	Forward required logs to SIEM; validate timestamps, parsing, retention, and alert use cases.	30 days	Search confirms complete events and alert test succeeds.
V-06	Shared service account has broad permissions and no defined owner	High	Business application	Poor accountability and lateral-movement opportunity.	Assign owner; rotate secret; reduce permissions; move to managed identity where feasible.	30 days	Access review + successful rotation + least-privilege test.
V-07	Backups are configured but restore testing evidence is stale	Medium	Core services	Recovery may fail during ransomware or outage.	Perform restore test; record RTO/RPO results; correct failed dependencies.	60 days	Signed restore-test evidence and lessons learned.

Prioritization Model

- Priority increases for internet exposure, known exploitation, privileged access, sensitive-data access, business-critical systems, and absent compensating controls.
- Severity alone does not determine deadline; an internally isolated medium finding may be lower priority than a high finding on a public administrative service.
- Exceptions require owner, rationale, compensating controls, expiration date, and approval.

Metrics for Management Reporting

Metric	Purpose
Critical findings open	Immediate exposure visibility
High findings past SLA	Remediation accountability
Mean days to remediate	Trend remediation speed
Repeat findings	Identify ineffective corrective action
Assets without authenticated coverage	Measure assessment blind spots
Validated closures	Distinguish fixed findings from ticket closure